

# Care Access Navigator

## Risk Management Rubric - Criterion 2: Risk Management Techniques

### 1. What Task 2 Requires

Task 2 requires a complete risk assessment process rather than only a definition of risk. The work must demonstrate the following six areas:

- Use three structured risk-identification methods: brainstorming, checklists, and SWOT analysis, with a documented facilitation approach.
- Perform qualitative risk analysis using a 5 x 5 risk matrix with defined likelihood and impact scales.
- Perform quantitative risk analysis using Expected Monetary Value (EMV) and Annualized Loss Expectancy (ALE), supported by stated assumptions.
- Complete a threat and vulnerability assessment with documented findings.
- Create a comprehensive risk register that records risks, scores, rationale, ownership, treatment, status, and evidence.
- Maintain historical tracking so changes to a risk can be seen over time instead of overwriting earlier assessments.

### 2. What We Are Doing for This Task

For the Care Access Navigator project, we will assess risks related to identity and access management, authentication, authorization, privileged access, workforce lifecycle, vendor access, access reviews, security monitoring, and access to simulated ePHI. The goal is to identify realistic risk scenarios, analyze how serious they are, quantify selected risks where possible, and document the results in a consistent risk register.

| Step | What we do                                                                     |
|------|--------------------------------------------------------------------------------|
| 1    | Define the assessment scope and terminology.                                   |
| 2    | Identify assets and important processes that could be affected.                |
| 3    | Identify risks using brainstorming, a structured checklist, and SWOT analysis. |
| 4    | Consolidate duplicate or overlapping findings into a single risk list.         |
| 5    | Analyze threats and vulnerabilities for each material risk.                    |
| 6    | Score each risk using likelihood and impact in a 5 x 5 matrix.                 |
| 7    | Document the reasoning behind each qualitative score.                          |
| 8    | Use EMV and ALE for selected risks to demonstrate quantitative analysis.       |
| 9    | Record all results in the master risk register.                                |
| 10   | Update risk history as controls are implemented or new evidence is collected.  |

### 3. Step 1 - Define the Risk Assessment Scope

The first step is to state exactly what the assessment covers. A clear scope prevents the assessment from becoming too broad and makes the later risk scores easier to justify.

Working scope statement: The assessment evaluates security and operational risks associated with identities, authentication, access permissions, privileged access, user lifecycle activities, vendor access, logging, monitoring, and simulated ePHI access within the Care Access Navigator environment.

### 4. Step 2 - Use Consistent Risk Terminology

Each risk should be described using the same basic chain so that the assessment remains clear and repeatable:

**Asset -> Threat -> Vulnerability -> Risk -> Control -> Residual Risk**

| Term  | How it is used in this task                                                                                                                    |
|-------|------------------------------------------------------------------------------------------------------------------------------------------------|
| Asset | Something of value that must be protected, such as an identity account, Keycloak configuration, application, access record, or simulated ePHI. |

| Term          | How it is used in this task                                                              |
|---------------|------------------------------------------------------------------------------------------|
| Threat        | A person, event, condition, or action that could cause harm.                             |
| Vulnerability | A weakness that could allow the threat to cause harm.                                    |
| Risk          | The possibility that a threat will exploit a vulnerability and create a negative impact. |
| Control       | A safeguard that reduces likelihood, impact, or both.                                    |
| Residual Risk | The risk that remains after controls are considered or implemented.                      |

## 5. Step 3 - Identify Assets and Processes

Before listing risks, identify what could be affected. This creates a traceable link between a risk and the part of the project it concerns.

| Asset ID | Asset / Process                  | Category           |
|----------|----------------------------------|--------------------|
| A01      | Keycloak IAM                     | Identity platform  |
| A02      | User Accounts                    | Identity           |
| A03      | RBAC Roles and Permissions       | Access control     |
| A04      | Privileged Accounts              | Identity / access  |
| A05      | Vendor Accounts                  | Third-party access |
| A06      | Simulated ePHI                   | Data               |
| A07      | Healthcare Applications          | Applications       |
| A08      | Authentication and Access Logs   | Security evidence  |
| A09      | JML and Access-Request Processes | Workflow           |
| A10      | Risk and Control Records         | GRC information    |

## 6. Step 4 - Identify Risks Using Three Required Methods

The same environment is reviewed from three different perspectives. The purpose is not to create three unrelated lists, but to improve coverage and reduce the chance of missing an important risk.

### 6.1 Method 1 - Brainstorming

Brainstorming is used to generate risk scenarios from the perspective of people who understand the environment. The discussion should be structured around the project components rather than being an open-ended conversation.

- What could go wrong?
- What threat could cause it?
- What weakness would allow it?
- What information or system would be affected?
- What would the security or business consequence be?
- What control currently reduces the risk?

Example risk ideas to validate against actual project evidence:

- Excessive permissions caused by incorrect RBAC configuration.
- A terminated user account remains active after offboarding.
- A user account is compromised because authentication controls are insufficient.
- A privileged account is misused or granted more access than required.
- A vendor account remains active after the authorized access period.
- Excessive access to simulated ePHI is not detected.
- Repeated failed login activity is not investigated.
- A mover retains permissions from a previous role.

- Incomplete logging prevents an effective investigation.
- An access request is approved without sufficient justification or review.

## 6.2 Method 2 - Structured Checklist

The checklist method uses predefined control questions to identify weaknesses consistently. The table below contains starter answers based on the current project state. Each item should be updated to Yes, No, Partial, or Not Yet Tested as configuration and testing progress. A No or Partial answer may create a risk or strengthen the evidence for an existing risk.

| Checklist Question                                                 | Current Answer | Risk / Evidence Note                                                                                                                              |
|--------------------------------------------------------------------|----------------|---------------------------------------------------------------------------------------------------------------------------------------------------|
| Are inactive or terminated accounts disabled promptly?             | Not Yet Tested | R02 - Leaver deprovisioning is defined in the project design, but prompt account disablement has not yet been validated through a completed test. |
| Is MFA required where appropriate?                                 | Partial        | R03 - Authentication controls are in scope, but MFA coverage and enforcement still need to be confirmed and tested.                               |
| Are privileged roles restricted and reviewed?                      | Partial        | R04 - Privileged roles are identified, but restriction, review, and monitoring controls are still being validated.                                |
| Are permissions based on job responsibilities and least privilege? | Partial        | R01 - RBAC and least-privilege principles are defined, but role-to-permission mappings still require implementation/testing evidence.             |
| Are vendor accounts time-limited or periodically reviewed?         | Not Yet Tested | R05 - Vendor/service access is in scope, but expiration dates and periodic review have not yet been demonstrated.                                 |
| Are periodic access reviews performed?                             | Not Yet Tested | R11 - Access-review capability is planned, but a completed periodic review and remediation record are not yet available.                          |
| Are failed authentication attempts monitored?                      | Not Yet Tested | R07 - Failed-login monitoring is a planned security use case; alerting and analyst review still require testing.                                  |
| Are role changes reviewed to remove old permissions?               | Not Yet Tested | R08 - The mover workflow is defined, but removal of prior-role permissions has not yet been tested.                                               |
| Are access approvals documented?                                   | Partial        | R10 - The access-request and approval workflow is defined, but end-to-end approval and provisioning evidence still needs to be captured.          |
| Are authentication and access events logged sufficiently?          | Partial        | R09 - Authentication/access logging is part of the design, but log completeness and investigation usefulness still need validation.               |

## 6.3 Method 3 - SWOT Analysis

SWOT analysis provides a broader view of internal strengths and weaknesses and external or contextual opportunities and threats. For Task 2, the most important outputs are the weaknesses and threats because they can be converted into specific risk statements.

| SWOT Area     | Working Analysis                                                                                                                                                                                                                                                         |
|---------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Strengths     | Centralized IAM approach using Keycloak; RBAC and least-privilege design; use of synthetic/non-production data; defined JML and access-request workflows; planned authentication/access logging and monitoring.                                                          |
| Weaknesses    | The environment is simulated rather than production; several workflows may still contain manual steps; MFA, privileged-access controls, monitoring, and access reviews are not yet fully validated; enterprise integrations and automation are limited by project scope. |
| Opportunities | Expand MFA coverage; automate JML and account expiration; strengthen privileged-access governance; perform recurring access certification; improve SIEM alerting and investigation workflows; expand risk and security dashboards.                                       |
| Threats       | Credential compromise; excessive or misconfigured access; insider misuse; stale or orphaned accounts; vendor/third-party access misuse; privilege escalation; unauthorized access to simulated ePHI; insufficient logging or missed security events.                     |

*Starter SWOT note: The entries above are current working observations for the project and are not final findings. They are to be adjusted as controls are implemented and tested.*

## 7. Step 5 - Document the Facilitation Approach

The rubric requires the identification process to be documented, not simply the final list of risks. The following information is to be recorded when the three methods are performed:

- Assessment date and version.
- Participants or roles involved.
- Scope reviewed.
- Materials used, such as architecture, configurations, logs, checklists, or test results.
- Questions used during brainstorming.
- How disagreements or duplicate risks were resolved.
- Final list of risks accepted for analysis.

Facilitation note template: On 9/18/2026, the Care Access Navigator environment was reviewed using structured brainstorming, an IAM/security checklist, and SWOT analysis. Findings from the three methods were consolidated. Duplicate findings were merged, unclear items were refined into risk statements, and each accepted risk was linked to an asset, threat, vulnerability, and potential impact.

## 8. Step 6 - Perform the Threat and Vulnerability Assessment

For each material risk, identify the asset, threat, vulnerability, likely consequence, and the control that currently exists. This section explains why the risk exists and creates the basis for later scoring.

| Asset                   | Threat                         | Vulnerability                       | Possible Consequence                  | Existing / Planned Control                    |
|-------------------------|--------------------------------|-------------------------------------|---------------------------------------|-----------------------------------------------|
| Keycloak / user account | Credential attacker            | Weak or insufficient authentication | Unauthorized account access           | Authentication policy / MFA where implemented |
| RBAC / EHR access       | Insider or configuration error | Excessive permissions               | Unauthorized access to simulated ePHI | RBAC and access review                        |
| User account            | Former workforce member        | Delayed deprovisioning              | Continued unauthorized access         | Leaver process                                |
| Privileged account      | Privileged user / attacker     | Excessive administrative rights     | System or data compromise             | Privileged role restrictions                  |
| Vendor account          | External user                  | Expired access remains active       | Unauthorized third-party access       | Vendor access review / expiration control     |

| Asset         | Threat                    | Vulnerability                      | Possible Consequence                             | Existing / Planned Control      |
|---------------|---------------------------|------------------------------------|--------------------------------------------------|---------------------------------|
| Security logs | Attacker or user activity | Insufficient monitoring or logging | Suspicious activity not detected or investigated | Logging and monitoring controls |

## 9. Step 7 - Perform Qualitative Risk Analysis

Qualitative analysis ranks risks using likelihood and impact. Each is scored from 1 to 5. The two values are multiplied to produce the inherent risk score before additional treatment is applied.

$$\text{Risk Score} = \text{Likelihood} \times \text{Impact}$$

### 9.1 Likelihood Scale

| Score | Rating         | Definition                                      |
|-------|----------------|-------------------------------------------------|
| 1     | Rare           | Highly unlikely under the current scenario.     |
| 2     | Unlikely       | Could occur, but is not expected often.         |
| 3     | Possible       | A realistic event that may occur.               |
| 4     | Likely         | Expected to occur under foreseeable conditions. |
| 5     | Almost Certain | Expected frequently or is highly probable.      |

### 9.2 Impact Scale

| Score | Rating        | Definition                                                                |
|-------|---------------|---------------------------------------------------------------------------|
| 1     | Insignificant | Minimal security or operational effect.                                   |
| 2     | Minor         | Limited effect requiring minor correction.                                |
| 3     | Moderate      | Noticeable security, operational, or compliance effect.                   |
| 4     | Major         | Significant impact requiring management attention and remediation.        |
| 5     | Severe        | Serious impact to sensitive access, operations, or compliance objectives. |

### 9.3 5 x 5 Risk Matrix

| Impact \ Likelihood | 1 | 2  | 3  | 4  | 5  |
|---------------------|---|----|----|----|----|
| 5                   | 5 | 10 | 15 | 20 | 25 |
| 4                   | 4 | 8  | 12 | 16 | 20 |
| 3                   | 3 | 6  | 9  | 12 | 15 |
| 2                   | 2 | 4  | 6  | 8  | 10 |
| 1                   | 1 | 2  | 3  | 4  | 5  |

Suggested rating bands (use consistently if retained):

- 1-4 = Low
- 5-9 = Moderate
- 10-14 = High
- 15-25 = Critical

### 9.4 Record the Scoring Rationale

A score without an explanation is weak evidence. The table below contains starter likelihood, impact, and risk scores for the first five identified risks. These are working assessment values and should be revised using current project facts, test results, configuration state, or other evidence.

Example format: Likelihood = [score] because [actual condition/evidence]. Impact = [score] because [specific consequence if the event occurs]. Therefore, the inherent risk score is [L x I].

| ID  | Risk                              | L | I | Score | Scoring Rationale                                                                                                                                |
|-----|-----------------------------------|---|---|-------|--------------------------------------------------------------------------------------------------------------------------------------------------|
| R01 | Excessive RBAC privileges         | 4 | 5 | 20    | L4: RBAC mappings are not fully validated. I5: excessive access could expose simulated ePHI. Score 20 (Critical).                                |
| R02 | Terminated account remains active | 3 | 5 | 15    | L3: leaver deprovisioning is not yet tested. I5: an active terminated account could enable unauthorized access. Score 15 (Critical).             |
| R03 | Credential compromise             | 4 | 5 | 20    | L4: MFA/authentication controls are not fully validated. I5: compromise could expose applications and simulated ePHI. Score 20 (Critical).       |
| R04 | Privileged account misuse         | 3 | 5 | 15    | L3: privileged-role controls are still being validated. I5: admin misuse could affect identities, settings, logs, or data. Score 15 (Critical).  |
| R05 | Expired vendor access             | 3 | 4 | 12    | L3: vendor expiration/review is not yet demonstrated. I4: stale third-party access could cause significant unauthorized access. Score 12 (High). |

## 10. Step 8 - Perform Quantitative Risk Analysis

Quantitative analysis demonstrates how selected risks can be translated into estimated financial exposure. Because this is a simulated academic environment, the monetary values may be scenario-based estimates, but the assumptions must be stated clearly and used consistently.

### 10.1 Annualized Loss Expectancy (ALE)

$$\text{SLE} = \text{Asset Value} \times \text{Exposure Factor}$$

$$\text{ALE} = \text{SLE} \times \text{Annualized Rate of Occurrence (ARO)}$$

Editable example:

| Input / Result  | Value     | Basis / Formula                                           |
|-----------------|-----------|-----------------------------------------------------------|
| Asset Value     | \$100,000 | Hypothetical value assigned for the educational scenario. |
| Exposure Factor | 30%       | Estimated percentage of value affected by one event.      |
| SLE             | \$30,000  | $\$100,000 \times 0.30$                                   |
| ARO             | 0.5       | Estimated occurrence once every two years.                |
| ALE             | \$15,000  | $\$30,000 \times 0.5$                                     |

### 10.2 Expected Monetary Value (EMV)

$$\text{EMV} = \text{Probability of Event} \times \text{Estimated Financial Impact}$$

Editable example: if a risk has a 25% probability and an estimated scenario impact of \$40,000,  $\text{EMV} = 0.25 \times \$40,000 = \$10,000$ .

Required note for final submission: These financial values are scenario-based educational estimates unless actual organizational data is available.

## 11. Step 9 - Build the Comprehensive Risk Register

The risk register is the central record for Task 2. Each accepted risk has enough information that another reviewer can understand what the risk is, why it received its score, what is being done about it, and what evidence supports the assessment.

| Required Register Field | What to enter                  |
|-------------------------|--------------------------------|
| Risk ID                 | Unique identifier such as R01. |

| Required Register Field      | What to enter                                                            |
|------------------------------|--------------------------------------------------------------------------|
| Date Identified              | Date the risk was first recorded.                                        |
| Asset / Process              | Project component affected.                                              |
| Risk Statement               | Clear cause-event-impact description.                                    |
| Threat                       | Source or event that could cause harm.                                   |
| Vulnerability                | Weakness that enables the threat.                                        |
| Existing Controls            | Safeguards already present.                                              |
| Likelihood                   | 1-5 score.                                                               |
| Likelihood Rationale         | Why that likelihood was selected.                                        |
| Impact                       | 1-5 score.                                                               |
| Impact Rationale             | Why that impact was selected.                                            |
| Inherent Risk Score          | Likelihood x Impact before additional treatment.                         |
| Risk Rating                  | Low / Moderate / High / Critical using the chosen scale.                 |
| SLE                          | Single Loss Expectancy if quantitative analysis is used.                 |
| ARO                          | Annualized Rate of Occurrence if used.                                   |
| ALE                          | Annualized Loss Expectancy if used.                                      |
| EMV                          | Expected Monetary Value if used.                                         |
| Risk Owner                   | Person or role responsible for the risk.                                 |
| Treatment Decision           | Mitigate, avoid, transfer, or accept.                                    |
| Planned / Additional Control | Action intended to reduce risk.                                          |
| Target Date                  | Expected completion date.                                                |
| Residual Likelihood          | Likelihood after treatment.                                              |
| Residual Impact              | Impact after treatment.                                                  |
| Residual Risk Score          | Residual likelihood x residual impact.                                   |
| Status                       | Open, in progress, accepted, monitored, closed, etc.                     |
| Last Review Date             | Most recent reassessment date.                                           |
| Evidence Reference           | Screenshot, log, test result, configuration, ticket, review record, etc. |

## 11.1 Write Clear Risk Statements

Plan is to use a consistent cause-event-impact structure. A strong risk statement explains what condition exists, what could happen because of it, and what the consequence would be.

**Because of [vulnerability], [threat/event] may occur, resulting in [impact].**

Example: Because role permissions may be broader than required, a user could receive excessive access, resulting in unauthorized access to simulated ePHI or other restricted functions.

## 12. Step 10 - Maintain Historical Tracking

Historical tracking means that old risk assessments are retained rather than replaced. When a control is implemented or new evidence becomes available, record a new assessment entry so that the change in risk can be demonstrated.

| Date       | Risk ID | L | I | Score | Change / Evidence                                          | Reason for Change                                      |
|------------|---------|---|---|-------|------------------------------------------------------------|--------------------------------------------------------|
| 09/18/2026 | R02     | 3 | 5 | 15    | Initial assessment; leaver workflow defined, test pending. | Current project state; validation evidence is pending. |

| Date | Risk ID | L | I | Score | Change / Evidence                             | Reason for Change                                        |
|------|---------|---|---|-------|-----------------------------------------------|----------------------------------------------------------|
| TBD  | R02     | - | - | -     | After leaver-control update (future).         | Reassess only when implementation evidence is available. |
| TBD  | R02     | - | - | -     | After follow-up deprovisioning test (future). | Use actual test results to confirm residual risk.        |

### 13. Treatment and Residual Risk

Although the primary focus of Task 2 is assessment, the risk register should record the proposed response because residual risk cannot be calculated without considering controls. The four standard treatment choices are:

- Mitigate: Reduce likelihood or impact by adding or improving controls.
- Avoid: Stop or change the activity that creates the risk.
- Transfer: Shift part of the financial or operational responsibility to another party where appropriate.
- Accept: Formally tolerate the risk because it is within the defined risk tolerance or further treatment is not justified.

After treatment, assignment of residual likelihood and residual impact using the same 1-5 scales will be done. Also will record the residual score separately from the original inherent score.

### 14. Short Summary of what the techniques are meant for:

In Task 2, Identification of realistic IAM and cybersecurity risks in the Care Access Navigator environment for HRMC using three required methods is done. Examining the threats and vulnerabilities behind those risks, rating them with a defined 5 x 5 likelihood-impact model, using EMV and ALE to demonstrate quantitative analysis and maintaining the results in an evidence-based risk register that can be updated as the project changes. The final document will reflect actual project conditions and will be clearly distinguished with completed controls, partially implemented controls, and items that have not yet been tested.

Important note. Starter values have been entered in the checklist, SWOT, qualitative scoring, and initial historical-tracking tables. They reflect the current working state of the project and will be revised when actual configuration, testing, observations, dates, and evidence become available.